

# 令和6年春 応用情報 午後問1【情報セキュリティ】小南中文解析



## 一、整体背景梳理

-  **业务与转型需求：**
  - Q社是一家在首都圈经营多家辅导班（学習塾）的教育机构，原本全是在线下教室面对面上课。
  - 学生和家长希望推行“线上+线下混合教学（ハイブリッド型授業）”，员工也希望远程办公（テレワーク）。
-  **旧架构的痛点（图1：传统境界型防御）：**
  - **设备老化：**总社和各校区的路由器、防火墙、服务器快到停产寿命（EOL）了，买新硬件维护成本极高。
  - **打补丁繁琐：**排查漏洞、判断补丁能不能打耗费大量精力。
  - **墙内失守：**靠路由器和防火墙（FW）划分内外网的“边界防护”，一旦内部终端中毒或遭遇钓鱼邮件，边界根本挡不住。
  - **缺乏感知：**发生安全事故时没有快速告警和察觉机制。
-  **新架构改革（图2：上云 + 零信任）：**
  - 废除所有自建物理服务器和网络边界设备，全面搬迁到 T社提供的云服务（SaaS）。
  - 员工发笔记本电脑+随身 Wi-Fi，学生用家里电脑上云上网课。
  - 引入 **零信任（Zero Trust）** 理念：不再信任任何网络通道，重点转为**终端加固（EDR）、身份认证加强（多因素认证/IDaaS）与统一日志告警（SIEM）**。

## 二、逐题深度解析

### 設問 1：传统边界防御的作用边界

- **参考答案：**  （パケットフィルタリングのポリシーで許可していない通信による、内部ネットワークへの侵入）

- 选项辨析：

- **イ（正确）**：防火墙（FW）的核心工作就是包过滤（Packet Filtering），根据配置好的访问控制策略阻断未放行的 IP、端口通信，阻止外部非许可流量直接渗透进内网。
- **ア（错误）**：管理员内部作案属于合法内部权限滥用，防火墙默认认为内网合法，无法依靠边界策略阻拦。
- **ウ（错误）**：钓鱼邮件里带附件，员工主动在本地点击运行，这种基于业务合法通道（443/25端口）传进来的恶意代码，传统边界防火墙查不出来。
- **エ（错误）**：路由器自身的漏洞被攻击导致断网，属于硬件层面的漏洞缺陷，边界防护防的是穿过边界的非法通信，保护不了硬件自身的漏洞。

## 設問 2：远程环境构建方针

### (1) 空栏 a（6字）

- 参考答案： **ゼロトラスト**（6字）
- 逻辑拆解：
  - 题干原话：“代之以不信任任何通信的〔a〕思考方式”。
  - 安全领域的核心哲学：“Never Trust, Always Verify（从不信任，始终验证）”，即**零信任（Zero Trust / ゼロトラスト）**。6个片假名字数完全对应。

### (2) 下划线②：通过采用 SaaS 可以免去的作业是什么？（25字以内）

- 参考答案： **セキュリティパッチ提供の調査及び適用の判断**（21字）
  - (别解：セキュリティパッチの確認と適用作業 / 19字)
- 逻辑拆解：
  - 查看上文 Q 社四项现存课题：
    1. 机器 EOL 面临换新（文中已明确写了通过废弃机器来解决）。
    2. **安全补丁（セキュリティパッチ）**的调研与可否适用判断极耗时间。
    3. 边界防护抵挡不住新攻击。
    4. 缺乏快速告警机制。
  - 切换到 SaaS 模式后，底层服务器和软件的漏洞打补丁全由云厂商负责，企业无需自己研判更新补丁。因此免去的烦琐作业就是“**セキュリティパッチ提供**

の調査及び適用の判断”。

### 設問 3：远程构建方案评估

#### (1) 下划线③：云代理（Proxy）要实现的具体安全对策（15字以内）

- 参考答案：業務上不要なサイトへの接続禁止（15字）
  - (別解：URL フィルタリング / 10字)
- 逻辑拆解：
  - 原文中反复强调对终端上网的要求：“貸与PCから業務上不要なサイトへの接続は禁止とする”。
  - 旧环境是在本地代理服务器上装 URL 过滤软件来实现这一条；新方案把上网流量收归到云端代理，依然要执行这项管控，直接摘抄原文字句即可。

#### (2) 下划线④：引入 SIEM 的目的（结合课题与方针，30字以内）

- 参考答案：セキュリティインシデントの発生を迅速に検知するため（25字）
- 逻辑拆解：
  - SIEM（安全信息与事件管理）的本质就是收集所有设备日志并做关联分析、异常告警。
  - 原文现状课题明写着：“セキュリティインシデントの発生を、迅速に検知する仕組みがない”。
  - 构建方针中也明确对照：“セキュリティインシデントの発生を迅速に検知する仕組みを導入する”。
  - 将两处完全一致的目标转述为“为了迅速检知安全事件的发生”即可拿满分。

#### (3) 下划线⑤：防止外借 PC 丢失导致泄密的合理对策（多选）

- 参考答案：ア、ウ
- 选项辨析：
  - ア（正确）：全盘加密（ストレージ全体を暗号化）。电脑丢了就算被拔下硬盘装到别处，没有密钥也读不出明文数据。
  - イ（错误）：贴防窥膜（のぞき見防止フィルム）。防的是在咖啡厅或电车上被旁边的人偷看屏幕，电脑一旦整体遗失被捡走，防窥膜毫无防泄密作用。

- **ウ（正确）**：远程锁定与远程擦除（リモートロック・リモートワイプ）。一旦遗失立刻从后台锁定电脑或擦除内部数据，标准的移动终端遗失对策。

#### 設問 4：方案强化与追加对策

##### (1) 下划线⑥：发生 Oday 攻击或无文件恶意软件时，EDR 软件的动作是什么？

- **参考答案**：**ア**（貸与PCをネットワークから遮断し、不審なプロセスを終了する）
- **选项辨析**：
  - **ア（正确）**：EDR（Endpoint Detection and Response）侧重于“感染后的快速响应与遏制（Containment）”。当发现未知病毒/可疑行为时，第一动作是将受害机器网络隔离（防横向扩散）并杀死可疑进程。
  - **イ / エ（错误）**：依靠已知行为或特征码在入口拦截，这是传统杀毒软件（EPP）的能力，对 Oday（未知漏洞）和无文件攻击（直接在内存运行）往往无效。
  - **ウ（错误）**：阻止机密外发是 DLP（数据防泄漏）的功能，不是 EDR 的核心定义。

##### (2) 空栏 b：强化身份验证的技术名称（5字）

- **参考答案**：**多要素認証**（5字）
  - (別解：2要素認証 / 5字)
- **逻辑拆解**：
  - 文中说明认证方式为：“知识信息（ID + 密码）”结合“所持信息（手机 App 收到的一次性验证码）”。
  - 身份认证三大要素：
    1. 知识信息（你知道什么，如密码）
    2. 所持信息（你拥有什么，如手机/令牌）
    3. 生体信息（你是什么，如指纹/人脸）
  - 这里组合了两个不同的要素，属于规范的 **多要素認証（MFA）** 或 **2要素認証（2FA）**。



### 三、核心考点速查

| 考察维度                                                                                    | 考点核心            | 原理要点                                        |
|-----------------------------------------------------------------------------------------|-----------------|---------------------------------------------|
|  防御理念  | 境界型防御 vs ゼロトラスト | 传统 FW 只防外不防内；零信任假设内网已沦陷，对一切访问严格验证。          |
|  云服务责任 | SaaS 的维护边界      | 基础架构与应用补丁由云服务商全权管理，租户摆脱繁重的 EOL 与 Patch 工作。  |
|  终端与对抗 | EDR 响应机制        | 传统防毒（EPP）防不住 0day/无文件攻击；EDR 负责感染后切断网络、止血隔离。 |
|  访问安全  | 多要素认证（MFA）      | 结合知识信息（密码）与所持信息（OTP），防止单凭撞库密码导致的非法登录。       |
|  安全分析  | SIEM 统一日志与态势感知  | 汇聚多设备日志集中分析，填补“无法快速发现安全事件”的监控空白。            |